PRDv3.0: Hawaii Hospitality Dashboard and Marketing Website: Lava Birds B&B

Name: Lilith Gannone

Date: 05/01/2026

Property Name: Lava Birds B&B

Island: Hawai'i Island

Visitor Segment: Honeymooners

The goal of the Lava Birds B&B application development is to create a responsive, easily navigable application for guests and system users. The application aims to drive user interest, provide real-time data to help potential guests make informed decisions about travel dates, and provide an authentication-protected interface for system users.

The Lava Birds application consists of three main pages: a public marketing page, a public visitor dashboard, and a protected admin dashboard.

A quiet, immersive stay near Kilauea, meant to be shared.

Live URL: https://ics385spring2026.onrender.com/

GitHub URL: https://github.com/lilithgannone/ics385spring2026/tree/main/week15/term-project

---

AI Attribution: Grammarly used to edit this PRD. ChatGPT used to understand functional elements, specifically request flow. AI design tools (Eraser.io) used to create the component architecture diagram.

Problem Statement & Target User:

Primary Target User: Budget-Conscious Honeymooners

Problem Statement

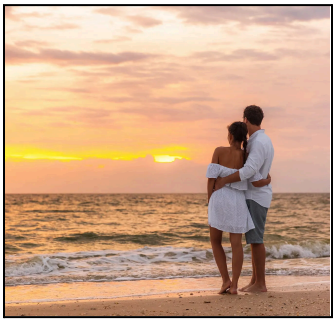
I am a budget-conscious traveler looking to book accommodations for my honeymoon. I can't find anything affordable online that offers unique and romantic experiences while allowing me to weigh my travel options. This is causing me stress and uncertainty.

The Opportunity

Hawai'i Island has a few existing B&B options near Kilauea, most of which offer somewhat affordable accommodations. Existing B&Bs, however, do not tailor guest experiences to reflect their proximity to Kilauea. Few offerings strongly target honeymooning couples, and packages that exist are usually found at luxury resorts. This fillable gap offers the unique opportunity to target a niche visitor segment: honeymooners seeking a romantic, immersive, and affordable experience.

User Personas

User Persona 1: Honeymooners



Profile/Role: A young couple who are planning a romantic honeymoon trip on a moderate budget.
Name: Maya and Ken
Goals:
- Find an affordable but memorable honeymoon experience
- Stay somewhere that feels unique and highlights the natural environment.
- Easily understand what the experience includes
- Make informed travel decisions

Pain Points:
- High costs of both unique and traditional luxury honeymoon experiences.
- Difficulty finding experiences that feel tailored to them without luxury pricing
- Potential for unpredictability in weather, volcanic activity, etc.

Security Statement: "As a user and guest, it is very important to me that my information is kept private so that I can feel safe inputting my information and booking with Lava Birds B&B. It's also very important to me that my stored information is not altered in any way by unauthorized users. I'd also like announcements to only be posed by authorized personnel."

User Persona 2: Property Admin

Profile/Role: A non-technical property owner managing Lava Birds B&B content.
Name: Thomas
Goals:
- Easily update property information, amenities, and packages
- Post special offers and updates
- Keep the website data current without needing to update it daily
- Drive user interest

Pain Points:
- Limited technical knowledge
- Limited time to update the website daily
- Risk of outdated or inaccurate information

Security Statement: "As a system administrator and manager, it is very important to me that only authenticated users can access guest information and post anything to the site. If an attacker were able to get in and post an unauthorized announcement with a phishing link for users, this would be a nightmare. It's also very important to me that my password is kept safe".

Functional Requirements

R1-R20 Must Exist and Have the Stated Structure/ Functionality

Marketing Page Requirements

Component	What is Displayed	Data Source	Interactive Behavior/ Responsive CSS Approach
R1 Hero	Property name, tagline, island, main image/background video.	MongoDB via Express API	Hero CTA button that navigates to the booking contact form, Amenities button.
R2 Special Offe Section	Current special offer and a CTA button prompting contact.	MongoDB via Express API	Button that opens to a contact form that sends a message to the admin. Accessible on the admin dash.

R3 Image Carousel	Carousel of property images.	MongoDB via Express API	Navigable arrows.
R4 About	Property description, location, target audience, lava.mp4, and owner information.	MongoDB via Express API	No major user interaction. Hover effects.
R5 Reviews	A form for guests to input reviews and a table of guest reviews	Some hardcoding. Some MongoDB via Express API	Guests can input reviews. Submi button. No links can be posted to prevent phishing.
R6 Amenities	Array of amenities: comfort-focused rooms, hot tubs, private outdoor access, local tea and coffee tastings, etc.	MongoDB via Express API	Renders amenities, no direct interaction.
R7 CTA	Booking prompt, button, and a highlight of special offers.	MongoDB with some static fallback, as we are not developing a booking page at this stage.	Button that opens to a contact form that sends a message to the admin. Accessible on the admin dash.
R8 Header/ Footer	Navigation links (Home, Dashboard, general nav, Admin) and copyright	Hardcoded and MongoDB/ Express API	Interactive navigation links that route users to the corresponding section.

Dashboard Design Requirements

Charts

	R9 Arrivalchart	**R10 Originchart**	**R11 Metriccards**
Data Source	DBEDT visitor arrivals data	DBEDT visitor origin data	DBEDT and estimates
Chart Type	Bar Chart	Doughnut Chart	Three KPI cards
Why It Matters	Users can make informed decisions about when they'd like to arrive based on monthly trends.	Users can understand who visits Hawai'i Island.	Show travelers market information so they can make informed travel decisions based on trends.

R12 Island Selector Ux

UI Control Chosen State	**Chosen State Variable Name**	**Components That Re-Render When Selection Changes**	**Why it Matters**
Dropdown menu	slctIsland	Arrivalchart, Originchart, Metriccards, WeatherWidget	Allows users to navigate to information on their chosen Island. Must be easy to use, and components must consistently reflect the selection.

Widgets

	Placement On Page	**City Queried**	**Loading State Handling; Data Fields Displayed**	**Why it Matters**
R13 Weather	Top left of the page, under the top user interactive section	Hilo, Hawai'i	"Loading" message, error handling; city name, temperature, conditions	Allows users to reflect on weather conditions. This can allow users to track daily weather through the site, boosting interaction.
R14 Volcano	Top middle of the page, to the right of the weather widget	Hilo, Hawai'i (Kilauea)	"Loading" message, error handling; eruption data, conditions	Allows users to reflect on volcanic activity. This can allow users to track activity through the site and make decisions on travel based on activity. The video may increase conversion.

R15 Live Stream	Top right of the page, To the right of the volc. widget	Hilo, Hawai‘i (Kilauea)	“Loading” message. Potential to add fallback to another stream.	Will drive interest for users. Users will get to see a real time stream of Kilauea.

Data Architecture

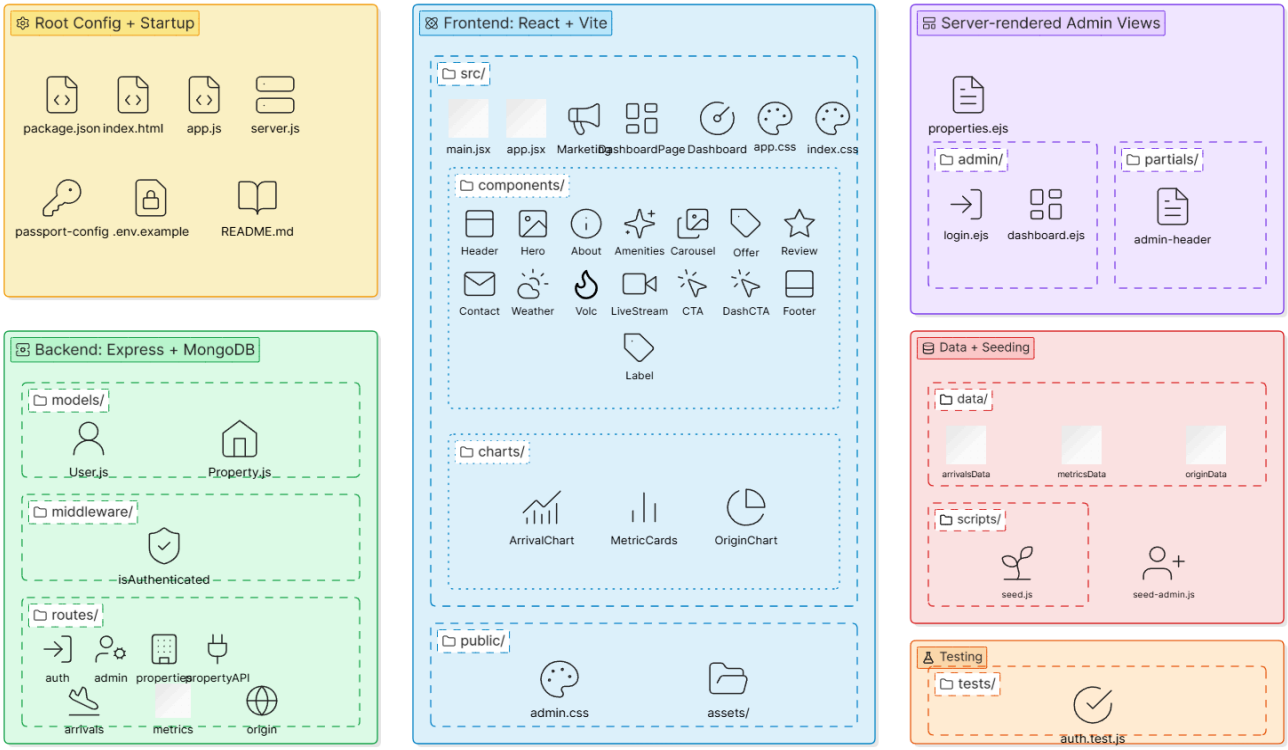
DBEDT Fields Used	JSON Schema Sketch	Express Route That Serves The Data
Island, Month, Arrivals, Metrics	{“ island”: "Hawai‘i", “month”: "Feb", “arrivals”: 182000, “market” (by mo): {“japan”: 20000, “canada”: 8000, “other”: 9000 }, “metrics”: {“lengthofstay”: 8.9, “expenditure”: 250, “occupancy”: 73%}}	GET /api/arrivals?island=Hawai’i

Admin Dash

R16 Login	R17 Manage Contact Messages	R18 View Reviews	R19 Post a Special Offer	R20 Property Records
Users can log in using local and Google OAuth 2.0 strategies [NEW v3].	View and clear customer contact messages posted through the marketing site.	View records of all customer reviews.	Manage the special offer section on the marketing page. Edit the current special offer.	View a list of all MongoDB property records.

Technical Architecture

Node.js, Express, EJS, React, MongoDB, Mongoose, Passport.js, Chart.js



Request Flow

Browser---React/EJS---Express Routes---PasportAuth Middleware---MongoDB/ JSON Data---Express Response---JSON/API/EJS HTML---Rendered UI

Authentication & Security

Admin User: An admin user has elevated privileges. They have the ability to make changes and view data that a normal system user cannot. Lava Birds B&B admins will be individuals granted these privileges, i.e., managers, specified employees, owners, etc.

Local Authentication

- Authentication Method-- Verifying Who the User Is: Email + password via Passport.js LocalStrategy.
- Login Flow
    - **Prior req:** admin registers via seed-admin.js
    - Admin visits “Admin” page
    - Admin enters email/ password
    - Form submits
    - **How is account linking handled?** Passport strategy checks user credentials on MongoDB
    - bcrypt checks the entered password against the stored hash (with a minimum of 10 salt rounds)
        - If validated, the user redirects to /admin/dashboard
        - If invalid, the user is redirected back to the login page, and an error message is displayed.
- Significant Authentication Design Decisions
    - The decision to hash passwords with bcrypt is the most significant design choice, as it will protect from attacks. If passwords were stored as plaintext, this would be a very high security risk. The choice to potentially implement session time-out measures is another significant security choice. This can prevent unlimited access sessions.
- Password Hashing
    - Passwords are hashed using bcrypt with a minimum of 10 or more salt rounds
    - Storing passwords as plain text will NOT be used. This is important as if passwords are stored as plain text, anyone with database access can see all passwords. This is a major security risk. For example, if someone hacked into the database, they would not need to take any other measures to access passwords. They would be unencrypted and displayed as plain text.
- Handling Failed Login Attempts
    - When a user inputs an incorrect password, they will be:
        - Redirected to /admin/login
        - An error message will display.

Google OAuth 2.0 Authentication [NEW v3]

- Authentication Method-- Verifying Who the User Is: Users authenticate through their Google account instead of registering and entering login info directly into the Lava Birds site.
- Login Flow
    - Admin visits “Admin” page
    - Admin selects “Sign in with Google.”
    - Admin is redirected to Google’s authentication screen.
    - User signs in to Google and grants permission, verifying the application name.
    - Google redirects the user: /auth/google/callback
    - **How is account linking handled?** Passport GoogleStrategy receives the user profile and verified email, and checks MongoDB for the same email. If nothing exists, passport checks for local login with the same email, and if it exists, the account is linked to that user. Otherwise, provision a new non-admin user (message will display that they have created an account, but they do not have admin privileges. Status/ privileges can be changed using admin-seed.js)
        - If validated, the user redirects to /admin/dashboard
        - If invalid, the user is redirected back to the login page, and an error message is displayed.
- Significant Authentication Design Decisions
    - Google OAuth was added as an authentication offering, allowing users to sign in with their existing Google accounts. On the user side, this eliminates the need to create a new account and remember credentials. On the developer side, it takes care of the complexities and security concerns of handling user authentication within the application. For example, if a user forgets their password, they can use Google's password recovery process instead of the application needing to implement its own. In addition, Google implements its own MFA and security measures-- taking away some of the responsibility of securing user accounts from the application.
- Handling Failed Login Attempts
    - When a user inputs an incorrect password, they will be:
        - An error message will display on the Google UI.
        - Potentially redirected to /admin/login

Questionnaire [NEW v3]

1. Which authentication strategies will the application support?
    a. This application supports both local and Google OAuth 2.0 passport-google-oauth20. Users can securely log in through the main site or log in using their Google credentials.
2. What is the user data model?
    a. Mongoose schema fields: googleId, email (unique, required), password (nullable), provider (enum local, google- default: local), role (enum under, admin- default: user), createdAt (default: Date.now).

3. How is account linking handled?
    a. Please see Login Flow.
4. How are sessions managed?
    a. The session will automatically end after one hour for security purposes. Admins must then log back in. Express-session with connect-mongo store; 14-day TTL; httpOnly, secure (in production), and sameSite cookie attributes.
5. How are secrets stored?
    a. SESSION_SECRET and MONGODB_URI, GOOGLE_CLIENT_ID [NEW v3], GOOGLE_CLIENT_SECRET [NEW v3], and API keys are in .env. The .env.example will be committed to GitHub to provide an example of a functional .env with placeholders for sensitive keys and information. .env is listed in .gitignore to ensure these are not posted publicly.
6. Which routes are protected?
    a. GET /admin/dashboard, POST /admin/special-offer, and POST /admin/contact-messages/delete-selected are protected routes. The middleware that guards it is: isAuthenticated.js. Admin/Login: All users can access the admin login page; not all users can proceed past this page. /Admin/Dashboard is used to access property information. /Admin/special-offer is used to post announcements to the marketing page. /admin/contact-messages/delete-selected allows admins to delete contact messages from the queue.
7. What threats does the design mitigate?
    a. The design mitigates unauthorized admin access, plain-text password exposure, unattended sessions, secret exposure, duplicate accounts, and phishing through unauthorized announcements.

Additional Security Risks to Consider

- XSS in review forms:
    - XSS attacks occur when attackers inject malicious scripts into trusted websites. Then, when users visit the page with the affected scripts, the browser executes this code, causing multiple security issues. This is an important consideration for Lava Birds B&B, as unprotected review forums could potentially allow for this type of attack.
    - Potential Future Protections: filter input on arrival, limit form fields to expected values, and use appropriate response headers.

Acceptance Criteria- 7 Automated Tests and 4 Manual Tests [NEW v3]

Acceptance Criteria Code	Description	Pass/Fail
AC1 (Automated)	GIVEN any visitor / WHEN they request GET / / THEN the marketing page returns HTTP 200 and renders the property name, hero image, and at least 3 amenities.	**P**
AC2 (Automated)	GIVEN a registered user / WHEN POST /login with correct credentials / THEN HTTP 302 to /admin/dashboard and a session cookie is set.	**P**
AC3 (Automated)	GIVEN any user with a Google account / WHEN they click "Sign in with Google" and consent / THEN HTTP 302 to /admin/dashboard, users collection contains a document with googleId and provider='google'.	**P**
AC4 (Automated)	GIVEN an unauthenticated visitor / WHEN they request /admin/dashboard / THEN HTTP 302 redirect to /login and no admin content is rendered.	**P**
AC5 (Automated)	GIVEN an authenticated user / WHEN they POST /logout / THEN session cookie is cleared and req.user is undefined on the next request.	**P**
AC6 (Automated)	GIVEN the deployed application / WHEN inspecting the GitHub repository / THEN .env is absent, .env.example is present, and no API keys appear in any file.	**P**
AC7 (Automated)	GIVEN that an admin visits the admin page/ WHEN they enter their password and are successfully authenticated/ THEN when they post an announcement, it successfully posts to the marketing page.	**P**
AC8 (Manual)	GIVEN that a user visits the marketing page/ WHEN the page loads/ THEN the lava video plays automatically without substantial load time and loops without interruption.	**P**
AC9 (Manual)	GIVEN that a user changes their island selection/ WHEN their choice is input/ THEN Arrivalchart, Originchart, Metriccards, and WeatherWidget update within 1-2 seconds.	**P**
AC10 (Manual)	GIVEN that a user visits the dashboard page/ WHEN the weather widget displays/ THEN it loads within 1-2 seconds and displays the loading message while loading.	**P**

AC11 (Manual)	GIVEN that a user visits the admin page/ WHEN they enter an invalid password using the local strategy/ THEN they will be redirected to the login page, and the error message will display/ AND if they use Google, the USER (no admin access unless listed in the seed script) account created message displays	**P**

Results:

```
> jest --runInBand tests/auth.test.js

 PASS  tests/auth.test.js
  HW15 acceptance tests
    √ AC-1 public marketing page route responds (21 ms)
    √ AC-2 local sign-in redirects to admin dashboard and sets session cookie (22 ms)
    √ AC-3 Google OAuth route redirects visitor to Google (5 ms)
    √ AC-4 unauthenticated admin dashboard request redirects to admin login (5 ms)
    √ AC-5 logout redirects to login and clears session cookie (4 ms)
    √ AC-6 secret hygiene files are configured correctly (2 ms)
    √ AC-7 admin can post an announcement that is available to the marketing page (22 ms)

Test Suites: 1 passed, 1 total
Tests:       7 passed, 7 total
Snapshots:   0 total
Time:        1.224 s, estimated 2 s
Ran all test suites matching /tests\\auth.test.js/i.
```

Additional Acceptant Criteria to Consider (Potential for Focus Group Testing)

Marketing Page:

- Given that a user visits the marketing page, when they navigate around the page, then they book a stay at a 4% conversion rate.
- Given that a user visits the marketing page, when they navigate around the page, then they are able to easily identify amenities and booking processes within 20 seconds without confusion.

Dashboard:

- Given that a user visits the dashboard page, when they would like to navigate to a specific section, then they are able to quickly and easily identify how to do so within 20 seconds without frustration, getting meaningful information from their search.

Admin:

- Given that an admin visits the admin page, when they enter their password and are successfully authenticated, then they are able to access information that helps them understand property data in an efficient way.